

CONTRACTE DE SERVEIS D'AUDITORIA SIMBÒLIC

ACORD DE PENTESTING: HEXON SECURITY I GLOBAL DATA SOLUTIONS

1. OBJECTE DEL SERVEI I IDENTIFICACIÓ DE LES PARTS

Aquest document formalitza l'encàrrec per part de GLOBAL DATA SOLUTIONS (GDS) (el Client) a HEXON SECURITY (l'Auditor) per realitzar una auditoria de seguretat informàtica (Pentesting). L'objectiu és simular un atac extern per tal de trobar i documentar els punts febles de seguretat del Client.

2. ABAST I DELIMITACIÓ TÈCNICA (OBLIGATORI)

L'auditoria se centrarà exclusivament en els següents elements de la infraestructura de GDS:

Servidor Web (Frontend): S'analitzarà el formulari de login de l'aplicació web per explotar la vulnerabilitat d'Injecció SQL.

Servidor de Gestió Interna: S'intentarà explotar un error de configuració degut a l'ús de programari antic, buscant l'Execució Remota de Codi (RCE). També es faran proves per accedir mitjançant credencials de fàbrica o molt dèbils (atac de força bruta ràpid).

No s'inclouen en l'abast d'aquesta feina els dispositius mòbils dels empleats, l'enginyeria social ni cap element de control d'accés físic.

3. FUNCIONS, PERMISOS I CAUTELES (OBLIGATORI)

El Client autoritza l'Auditor a dur a terme les proves d'exploració i explotació necessàries, tal com s'estableix en la fase d'Explotació de la nostra planificació.

Accions permeses: Es permet l'ús d'eines de Pentesting (com la nostra aplicació Python desenvolupada) per simular l'atac. Si s'aconsegueix accedir-hi, es podrà recopilar la prova mínima per demostrar l'èxit de la vulnerabilitat (una llista d'arxius o una entrada de base de dades).

Limitacions clares: L'Auditor no tindrà accés d'administrador als servidors i es compromet a no fer modificacions permanents ni esborrar dades o configuracions del sistema. La nostra tasca és simular, no causar danys.

4. CONFIDENCIALITAT I LLIURAMENT DE RESULTATS

L'Auditor es compromet a protegir tota la informació a la qual accedeixi (dades i detalls de les vulnerabilitats). Un cop finalitzat el servei, HEXON SECURITY lliurarà l'informe d'auditoria al client. Aquest informe no només inclourà les proves de l'atac, sinó també una llista de recomanacions de solució detallades, que és la part més important de la nostra feina de consultoria.

Aquest contracte és un acord simbòlic amb finalitats educatives dins el marc del projecte d'ASIX.

El Grup 3 (Hexon Security) es compromet a respectar els termes d'aquest acord.